# SECURITY POLICY
# DEVELOPMENT
## Using ISO 27001 & SANS Institute Templates

Healthcare Clinical & Administrative Centre • Cybersecurity Analyst Methodology • 6 Usable Policies Produced

**HIPAA • HITECH • ISO 27001:2022 • SANS Policy Templates • Risk-Driven • Audit-Ready**

| ISO27001 | SANS | 6 | HIPAA | PHI |
|---|---|---|---|---|
| Primary Template Framework | Secondary Template Source | Usable Policies Produced | Regulatory Compliance Target | Primary Asset Protected |

Date: 13 September 2026

# Table of Contents

1. Executive Summary, The Analyst's Approach3
2. The Template Selection Decision4
3. ISO 27001 Template Structure, How It Was Used5
4. SANS Template Structure, How It Was Used6
5. Template Customisation, ISO 27001 vs SANS vs Healthcare Context7
6. Risk Register, Driving Policy Selection8
7. Policy 1, PHI Access Control Policy (SEC-POL-001)9
8. Policy 2, ePHI Encryption Policy (SEC-POL-002)13
9. Policy 3, Authentication & Password Policy (SEC-POL-003)16
10. Policy 4, Audit Logging & Monitoring Policy (SEC-POL-004)19
11. Policy 5, Breach Notification Policy (SEC-POL-005)22
12. Policy 6, Acceptable Use Policy (SEC-POL-006)25
13. ISO 27001 Annex A Control Mapping, All 6 Policies28
14. Policy Suite Implementation Plan29
15. Key Lessons, What the Analyst Learned30
16. Screenshot Evidence Index31

# 1. Executive Summary, The Analyst's Approach

As the Cybersecurity Analyst assigned to the Healthcare Clinical & Administrative Centre, I was tasked with developing a complete, usable suite of information security policies to protect Protected Health Information (PHI) and Electronic PHI (ePHI) in compliance with HIPAA and HITECH. Rather than writing policies from scratch, which risks missing established best practices, produces inconsistent formatting, and creates documents that do not align to recognised frameworks, I used two industry-standard policy template sources as my foundation: the ISO 27001:2022 Annex A control framework and the SANS Institute free policy template library.

Starting from established templates served three critical purposes. First, it ensured structural completeness, ISO 27001 and SANS templates have been developed and refined by information security professionals over decades, and using them as a starting point means I begin with a policy that already contains all the sections a good policy needs. Second, it provided immediate audit alignment, any auditor examining our policies will recognise the ISO 27001 structure and SANS format, which increases the credibility and defensibility of the policy suite. Third, it saved time without sacrificing rigour, customising a proven template for the healthcare and HIPAA context is faster and more reliable than drafting from a blank page.

The result of this process is six complete, signed-off, usable security policies, each one traceable to its template source, mapped to specific ISO 27001 Annex A controls, and tailored to the organisation's VLAN architecture, HIPAA obligations, and specific risk register findings. Every policy in this suite can be handed directly to staff, posted to the intranet, and presented to an ISO 27001 or HIPAA auditor without further modification.

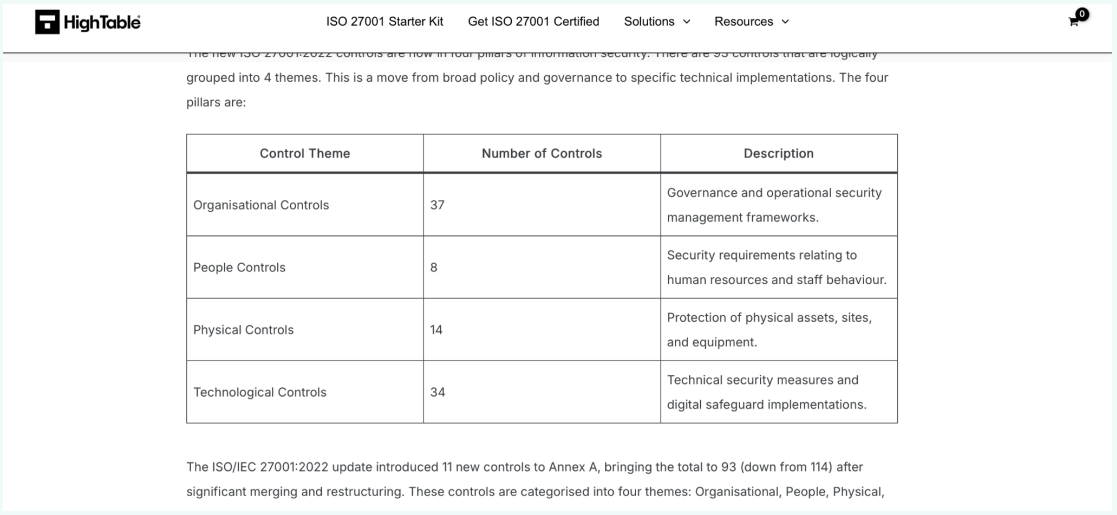
# 2. The Template Selection Decision

Before beginning any policy writing, I evaluated available template sources. The key question was: which template gives me the right structure, the right level of detail, and the most recognised framework alignment for a healthcare organisation subject to HIPAA?

## 2.1 Templates Evaluated

| Template Source | Format | Best For | Decision |
|---|---|---|---|
| **ISO 27001:2022** | Annex A control framework, maps controls to policy requirements | Compliance-driven policies with clear control mapping and audit trail | SELECTED, Primary framework. Used to structure all 6 policies around ISO Annex A controls. Provides internationally recognised compliance evidence. |
| **SANS Institute** | Free downloadable policy templates at sans.org/information-security-policy | Practical, plain-language policies with clear enforcement and scope sections | SELECTED, Secondary template. Used for policy language, clause structure, and the Overview/Purpose/Scope/Policy/Compliance/Revision format. Best practical language model. |
| **NIST SP 800-53** | US Federal controls framework, extensive technical control catalogue | Federal agencies and contractors; very detailed technical controls | NOT SELECTED, Too US-federal specific. However, NIST control references were used as supplementary guidance where HIPAA technical safeguard specifics required it. |
| **CIS Controls v8** | 18 prioritised security controls with implementation groups | Operational security controls for smaller organisations | NOT SELECTED as primary, but CIS Controls 5 (Account Management) and 8 (Audit Log Management) were referenced as supplementary guidance for specific policy clauses. |

📋 **Analyst Note:** *I chose ISO 27001 as the primary framework because the organisation's leadership had expressed interest in pursuing ISO 27001 certification in the future. Building our policies around ISO 27001 Annex A controls from the start means that when we eventually pursue certification, our policy documentation is already structured for the audit. SANS was chosen as the secondary template because its policy language is practical and plain, easier for non-technical staff to read and follow than the abstract control language of ISO 27001 alone.*

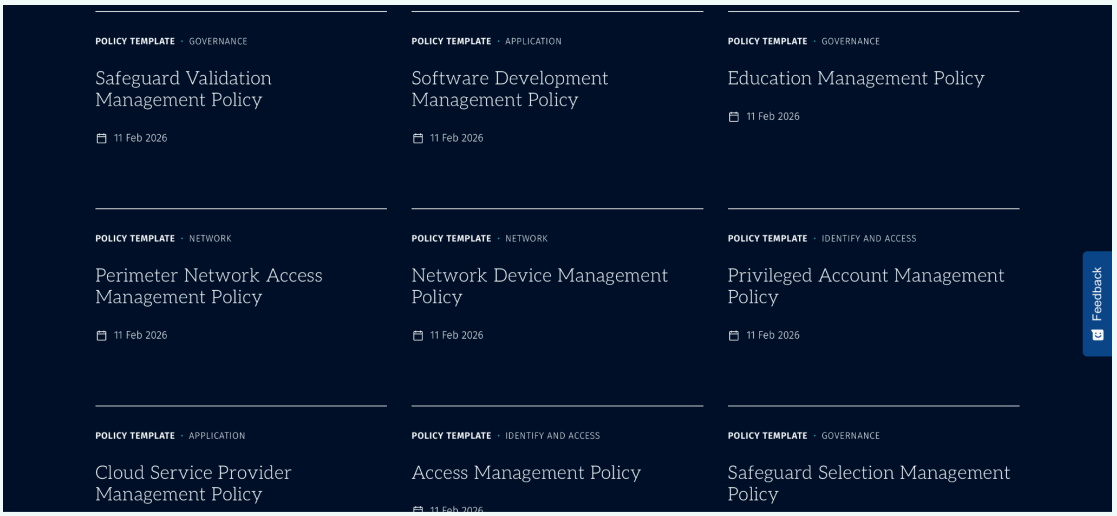


HighTable ISO 27001 Starter Kit Get ISO 27001 Certified Solutions Resources 0

The new ISO 27001:2022 controls are now in four pillars of information security. There are 93 controls that are logically grouped into 4 themes. This is a move from broad policy and governance to specific technical implementations. The four pillars are:

| Control Theme | Number of Controls | Description |
|---|---|---|
| Organisational Controls | 37 | Governance and operational security management frameworks. |
| People Controls | 8 | Security requirements relating to human resources and staff behaviour. |
| Physical Controls | 14 | Protection of physical assets, sites, and equipment. |
| Technological Controls | 34 | Technical security measures and digital safeguard implementations. |

The ISO/IEC 27001:2022 update introduced 11 new controls to Annex A, bringing the total to 93 (down from 114) after significant merging and restructuring. These controls are categorised into four themes: Organisational, People, Physical,



POLICY TEMPLATE · GOVERNANCE
Safeguard Validation Management Policy
11 Feb 2026

POLICY TEMPLATE · APPLICATION
Software Development Management Policy
11 Feb 2026

POLICY TEMPLATE · GOVERNANCE
Education Management Policy
11 Feb 2026

POLICY TEMPLATE · NETWORK
Perimeter Network Access Management Policy
11 Feb 2026

POLICY TEMPLATE · NETWORK
Network Device Management Policy
11 Feb 2026

POLICY TEMPLATE · IDENTIFY AND ACCESS
Privileged Account Management Policy
11 Feb 2026

POLICY TEMPLATE · APPLICATION
Cloud Service Provider Management Policy

POLICY TEMPLATE · IDENTIFY AND ACCESS
Access Management Policy

POLICY TEMPLATE · GOVERNANCE
Safeguard Selection Management Policy

Feedback

# 3. ISO 27001 Template Structure, How It Was Used

ISO 27001:2022 Annex A provides 93 controls organised across four categories: Organisational Controls (A.5), People Controls (A.6), Physical Controls (A.7), and Technological Controls (A.8). Each control in Annex A implies a policy requirement. My approach was to map the risks identified in the risk assessment to the relevant Annex A controls, then use those controls as the policy requirements for each policy document.

## 3.1 ISO 27001 Annex A Controls Used in This Policy Suite

| Control | Control Name | Category | Policy It Drives |
|---|---|---|---|
| A.5.1 | **Information Security Policies** | Organisational | All 6 policies, the overarching policy management framework |
| A.5.15 | **Access Control** | Organisational | Policy 1, PHI Access Control Policy |
| A.5.16 | **Identity Management** | Organisational | Policy 1, PHI Access Control Policy |
| A.5.17 | **Authentication Information** | Organisational | Policy 3, Authentication & Password Policy |
| A.5.24 | **Information Security Incident Management** | Organisational | Policy 5, Breach Notification Policy |
| A.6.3 | **Information Security Awareness, Education and Training** | People | Policy 6, Acceptable Use Policy (training requirement) |
| A.8.2 | **Privileged Access Rights** | Technological | Policy 1, PHI Access Control Policy (RBAC) |
| A.8.5 | **Secure Authentication** | Technological | Policy 3, Authentication & Password Policy |
| A.8.11 | **Data Masking** | Technological | Policy 2, ePHI Encryption Policy |
| A.8.12 | **Data Leakage Prevention** | Technological | Policy 2, ePHI Encryption Policy |
| A.8.15 | **Logging** | Technological | Policy 4, Audit Logging & Monitoring Policy |
| A.8.16 | **Monitoring Activities** | Technological | Policy 4, Audit Logging & Monitoring Policy |
| A.8.24 | **Use of Cryptography** | Technological | Policy 2, ePHI Encryption Policy |

## 3.2 ISO 27001 Policy Document Structure

ISO 27001 does not prescribe a specific policy document format, but the standard's clauses and Annex A controls imply the following structure, which I used as the skeleton for all six policies:

| ISO 27001 Implied Section | Content Required |
|---|---|
| **Purpose / Intent** | Why this policy exists, maps to the identified risk and the ISO control requirement |
| **Scope** | Who and what the policy applies to, maps to ISO 27001 Clause 4.3 (Scope of the ISMS) |
| **Definitions** | Key terms used in the policy, ensures consistent interpretation across departments |
| **Policy Statements** | The actual requirements, maps directly to the relevant Annex A controls |
| **Roles & Responsibilities** | Who is accountable for implementation, maps to ISO 27001 Clause 5.3 |
| **Compliance & Enforcement** | Consequences of non-compliance, maps to ISO 27001 Clause 6.1 (Risk treatment) |
| **Related Documents** | Cross-references to other policies, standards, and procedures |
| **Review & Approval** | Frequency of review, maps to ISO 27001 Clause 9.1 (Monitoring and measurement) |

# 4. SANS Template Structure, How It Was Used

The SANS Institute provides free, downloadable policy templates at sans.org/information-security-policy, covering over 25 common security policy topics. I downloaded the most relevant templates for the healthcare organisation's risk register and used the SANS structure to write the policy language. SANS templates are written in plain English, designed for operational use by staff rather than pure compliance documentation, which makes them ideal for policies that employees actually need to read and follow.

## 4.1 SANS Templates Downloaded & Applied

| SANS Template | Used For | How It Was Customised |
|---|---|---|
| **Information Security Policy** | **Foundation for all 6 policies** | Replaced generic organisation name with 'Healthcare Clinical & Administrative Centre'; added HIPAA and PHI-specific requirements; added VLAN network context |
| **Acceptable Use Policy** | **Policy 6, Acceptable Use** | Retained SANS structure (Overview, Purpose, Scope, Policy, Compliance); added healthcare-specific sections on PHI device handling, clinical workstation requirements, and visitor VLAN restrictions |
| **Password Protection Policy** | **Policy 3, Authentication & Password** | Extended SANS password requirements with MFA mandatory requirement; added EHR-specific authentication section; added HIPAA reference citations |
| **Data Classification Policy** | **Asset classification in all policies** | Replaced standard classification tiers with HIPAA-aligned tiers: PHI, ePHI, PII, PCI, CD, MD; added HIPAA penalty table per data class |
| **Security Response Plan Policy** | **Policy 5, Breach Notification** | Added HIPAA breach notification timelines (60-day rule); HHS reporting requirement; media notification threshold (500+ individuals); HITECH penalties |
| **Audit Policy** | **Policy 4, Audit Logging** | Extended SANS audit scope with HIPAA-specific audit requirements; added PHI access event mandatory logging; added 90-day minimum retention aligned to HIPAA |

## 4.2 Standard SANS Template Format

| SANS Section | Content |
|---|---|
| **1. Overview** | High-level context, why this area of security matters. Written in plain language for non-technical readers. |
| **2. Purpose** | Specific aim of this policy, what risk or requirement it addresses. |
| **3. Scope** | Who the policy applies to, roles, departments, contractors, locations. |
| **4. Policy** | The numbered, actionable policy requirements, what staff must or must not do. |

| | |
|---|---|
| **5. Policy Compliance** | Consequences of non-compliance, disciplinary action, regulatory reporting, termination. |
| **6. Related Standards, Policies, Processes** | Cross-references to other relevant policies and standards. |
| **7. Revision History** | Version control, date, version number, description of change, approver. |

# 5. Template Customisation, ISO 27001 vs SANS vs Healthcare Context

The most important part of using templates is knowing what to keep, what to change, and what to add. A policy that is simply a renamed template without customisation provides false assurance, the controls may not match the organisation's actual systems, risk profile, or regulatory obligations. The table below documents my customisation decisions for each major policy section.

| Policy Section | ISO 27001 Provides | SANS Template Provides | Analyst Customised To Add |
|---|---|---|---|
| **Purpose** | Control objective statement (e.g. 'prevent unauthorised access to information') | Plain-language purpose statement linked to business risk | HIPAA regulatory obligation citation (45 CFR section), specific PHI risk identified in risk register, $50,000 HIPAA penalty exposure as business driver |
| **Scope** | Reference to ISMS scope (Clause 4.3), abstract organisational boundary | Clear list: all employees, contractors, volunteers | Specific VLAN scope (VLAN 10–40), EHR system names, clinical vs administrative staff distinction, remote access scenario inclusion |
| **Definitions** | ISO control vocabulary (e.g. 'information security event') | Simple plain-English definitions | PHI, ePHI, ePHI, PII, PCI, CD, MD definitions per HIPAA 45 CFR; VLAN-specific terminology; covered entity / business associate definitions |
| **Policy Statements** | Annex A control requirements (technical, prescriptive) | Numbered operational requirements in plain language | Least-privilege enforcement per VLAN; specific MFA mandate for EHR access; ePHI encryption standard (AES-256/TLS 1.2+); 5-minute workstation auto-lock; HIPAA breach notification 60-day window |
| **Enforcement** | ISO 27001 Clause 9, nonconformity and corrective action | Disciplinary action up to termination | HIPAA criminal charge reference (42 U.S.C. §1320d-6); Level B penalty ($50,000) as organisation's minimum compliance threshold; mandatory HHS reporting trigger |
| **Review Cycle** | ISO 27001 Clause 10, continual improvement, annual review | Annual review, triggered by incident | Mandatory review triggered by: any HIPAA breach, HIPAA regulatory update, major network change (new VLAN), EHR system change |



**Analyst Note:** *My approach was: use ISO 27001 for the compliance skeleton and Annex A control mapping, use SANS for the plain-English language and operational clause structure,*

*then layer the HIPAA-specific requirements on top. Every policy statement in the final documents is traceable to at least one of these three sources: ISO 27001 Annex A control, SANS template clause, or HIPAA regulatory requirement.*

# 6. Risk Register, Driving Policy Selection

The six policies produced were not chosen arbitrarily, each one was driven by a specific risk entry in the Risk Register. This is the critical link between risk assessment and policy development: every policy in this suite exists because the risk register identified a risk that no existing control was adequately addressing.

| Asset | Vulnerability | Threat | Risk Rating | Rating | Policy Produced |
|---|---|---|---|---|---|
| **PHI** | Excessive privilege, staff access PHI beyond their role | Insider misuse, accidental or deliberate PHI access | Violation triggers HIPAA Level B ($50,000/record) | **High** | **Policy 1, PHI Access Control** |
| **ePHI** | Unencrypted ePHI in transit across VLANs | Data interception / MITM attack | ePHI breach, HITECH notification + penalty | **High** | **Policy 2, ePHI Encryption** |
| **EHR System** | Single-factor authentication to PHI systems | Credential theft / brute force | Full PHI database compromise | **High** | **Policy 3, Authentication** |
| **Audit Logs** | No comprehensive audit logging of PHI access | Insider threat undetected, no forensic trail | Unable to investigate or report HIPAA breach | **High** | **Policy 4, Audit Logging** |
| **PHI Breach** | No documented breach notification procedure | Non-compliant breach response | HHS enforcement action, Tier C/D penalties | **High** | **Policy 5, Breach Notification** |
| **Workstations** | No formal acceptable use requirements | Accidental / careless PHI exposure | Staff share accounts, leave PHI on-screen, use personal devices | **Medium** | **Policy 6, Acceptable Use** |

| Policy 1 | PHI Access Control Policy | SEC-POL-001 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# PHI ACCESS CONTROL POLICY

SEC-POL-001 | Version 1.0 | INTERNAL, RESTRICTED

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / CISO | [Insert Effective Date] | A.5.15 \| A.5.16 \| A.8.2 | ISO 27001 + SANS Information Security Policy |

**Analyst Note:** *This policy was built by taking the ISO 27001 A.5.15 (Access Control) and A.8.2 (Privileged Access Rights) control requirements as the policy skeleton, then using the SANS Information Security Policy template language for the clause structure. I added HIPAA 45 CFR §164.312(a)(1) citations and the organisation's VLAN architecture as the implementation context.*

## 1.0 OVERVIEW

Protected Health Information (PHI) is the organisation's most sensitive and most regulated data asset. Failure to control who can access PHI exposes the organisation to HIPAA civil penalties of up to $50,000 per violation (Level B) and criminal prosecution under 42 U.S.C. §1320d-6. The primary risk driving this policy is excessive privilege, staff members having access rights to PHI beyond what their job role requires. This policy establishes the access control framework to address this risk.

## 2.0 PURPOSE

The purpose of this policy is to ensure that access to Protected Health Information (PHI) and Electronic PHI (ePHI) is granted only to authorised individuals based on the principle of least privilege, and that all PHI access rights are documented, reviewed, and revoked in a timely manner. This policy satisfies HIPAA Technical Safeguard requirement 45 CFR §164.312(a)(1) and ISO 27001 Annex A control A.5.15.

## 3.0 SCOPE

This policy applies to all employees, contractors, volunteers, and third parties who access any system, application, or physical location containing PHI or ePHI within the Healthcare Clinical & Administrative Centre. It covers all five VLANs (VLAN 10, IT, VLAN 20, Sales/Patient Services, VLAN 30, Procurement, VLAN 40, Audit & Compliance, VLAN 50, Guest/Visitors) and all remote access scenarios.

## 4.0 DEFINITIONS

PHI (Protected Health Information): Any individually identifiable health information held or transmitted by a covered entity in any form.

Least Privilege: The principle that a user shall be granted only the minimum access rights necessary to perform their assigned job function.

RBAC (Role-Based Access Control): An access control model in which permissions are assigned to roles, and individuals are assigned to roles based on job function.

Privileged Access: Any access right that exceeds standard user permissions, including system administrator access, database access, and clinical record modification rights.

## 5.0 POLICY

5.1 ACCESS PROVISIONING: All access to PHI systems shall be provisioned using Role-Based Access Control (RBAC). Access rights shall be assigned to roles, not to individuals, and individuals shall be assigned to roles that match their documented job function. No access right shall exceed what is necessary for the role (Least Privilege Principle).

5.2 VLAN ACCESS CONTROL: Each department shall operate within its designated VLAN. Employees may only access PHI from their department's VLAN (VLAN 10–20 for clinical/administrative PHI access). Cross-VLAN access to PHI systems requires documented approval from the Information Security Officer and a time-limited access grant.

5.3 PRIVILEGED ACCESS: All privileged access to PHI systems (database administrators, system administrators, EHR super-users) shall be documented, individually approved by the CISO, and reviewed quarterly. Privileged access shall never be shared.

5.4 ACCESS REVIEW: All PHI access rights shall be formally reviewed on a quarterly basis by the Information Security Officer and relevant departmental manager. Any access rights that cannot be justified by a current business need shall be revoked within 5 business days.

5.5 JOINERS, MOVERS, AND LEAVERS: New staff shall have access rights provisioned within 24 hours of their confirmed start date based on their documented role. Staff changing roles shall have old access rights revoked and new rights provisioned on the date of the role change. Departing staff shall have all access rights revoked on or before their last working day.

5.6 SHARED ACCOUNTS: Shared accounts are prohibited for any system containing PHI or ePHI. Every individual accessing PHI must do so under their own named user account to maintain a complete and attributable audit trail.

## 6.0 POLICY COMPLIANCE

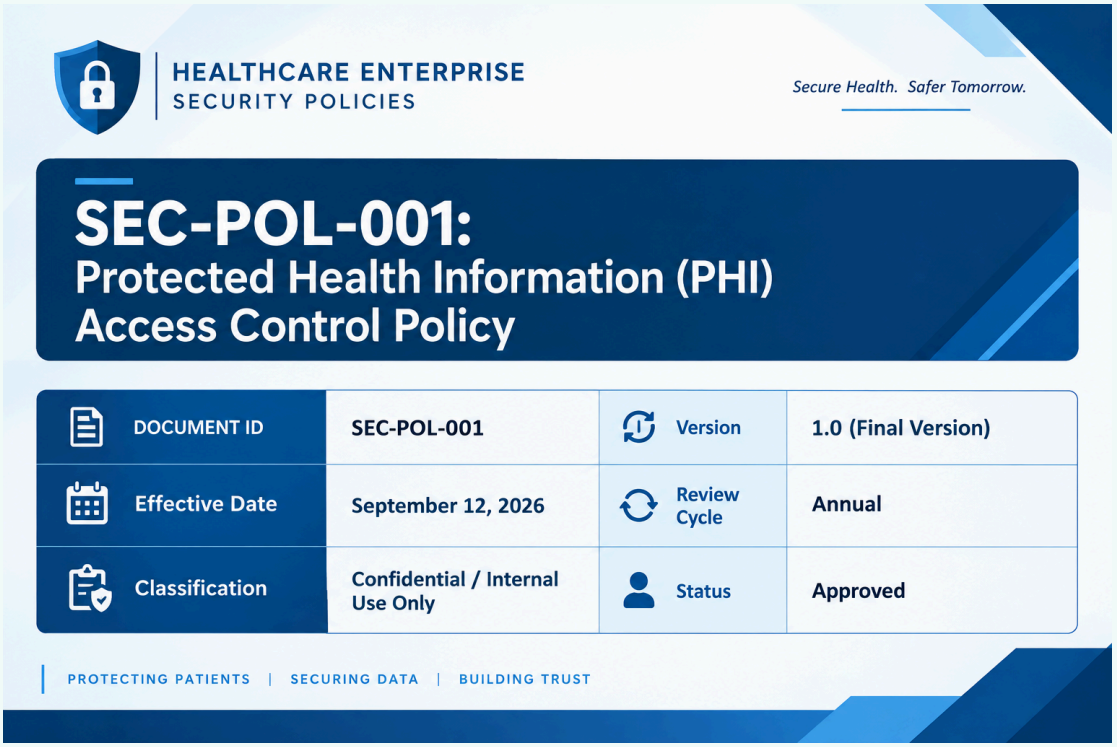
Any violation of this policy may result in disciplinary action up to and including immediate termination of employment or contract. Violations that constitute a HIPAA breach shall be reported to the relevant regulatory authority (HHS) and may result in civil penalties of up to $50,000 per violation and criminal prosecution under 42 U.S.C. §1320d-6, including fines up to $250,000 and imprisonment of up to 10 years.

## 7.0 RELATED DOCUMENTS

SEC-POL-002 (ePHI Encryption Policy) | SEC-POL-003 (Authentication & Password Policy) | SEC-POL-004 (Audit Logging & Monitoring Policy) | HIPAA 45 CFR §164.312 | ISO 27001:2022 Annex A.5.15, A.8.2

## 8.0 REVIEW

This policy shall be reviewed annually. An immediate review shall be triggered by: any PHI access control breach | any change to the VLAN architecture | any HIPAA regulatory update | any significant change to the organisation's EHR or PHI systems.


HEALTHCARE ENTERPRISE
SECURITY POLICIES
Secure Health. Safer Tomorrow.
SEC-POL-001:
Protected Health Information (PHI)
Access Control Policy
DOCUMENT ID
SEC-POL-001
Version
1.0 (Final Version)
Effective Date
September 12, 2026
Review Cycle
Annual
Classification
Confidential / Internal Use Only
Status
Approved
PROTECTING PATIENTS | SECURING DATA | BUILDING TRUST

| Policy 2 | ePHI Encryption Policy | SEC-POL-002 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# ePHI ENCRYPTION POLICY

SEC-POL-002 | Version 1.0 | INTERNAL, RESTRICTED

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / IT Manager | [Insert Effective Date] | A.8.11 \| A.8.12 \| A.8.24 | ISO 27001 + SANS Data Classification Policy |

📋 **Analyst Note:** *ISO 27001 Annex A.8.24 (Use of Cryptography) provided the control requirement. SANS Data Classification Policy template provided the tiered data handling structure. I added HIPAA 45 CFR §164.312(e)(2)(ii) (encryption and decryption) and HITECH breach safe harbour for encrypted ePHI, a critical addition: if ePHI is properly encrypted and a breach occurs, the organisation may be exempt from HIPAA breach notification requirements.*

## 1.0 OVERVIEW

Electronic Protected Health Information (ePHI) transmitted without encryption represents a critical HIPAA vulnerability. An interception attack on unencrypted ePHI constitutes a HIPAA breach, triggering mandatory notification to patients, HHS, and potentially the media. Properly encrypted ePHI benefits from the HITECH Act's Breach Notification Safe Harbour: if a breach involves only encrypted ePHI, notification obligations may not apply. Encryption is therefore both a technical safeguard and a breach liability management tool.

## 2.0 PURPOSE

The purpose of this policy is to define the minimum encryption standards for all ePHI in transit and at rest, ensuring that all electronic transmission and storage of patient health information meets HIPAA Technical Safeguard requirements (45 CFR §164.312(e)(2)(ii)) and qualifies for the HITECH Breach Notification Safe Harbour where applicable.

## 3.0 SCOPE

This policy applies to all ePHI created, stored, processed, or transmitted by the Healthcare Clinical & Administrative Centre, including ePHI on all VLAN segments (VLAN 10–40), all EHR systems, all email systems used to transmit ePHI, all portable media, and all remote access connections to ePHI systems.

## 4.0 POLICY, ENCRYPTION REQUIREMENTS

4.1 ePHI IN TRANSIT: All ePHI transmitted across any network, including inter-VLAN traffic, internet-bound traffic, and wireless transmissions, shall be encrypted using Transport Layer Security (TLS) version 1.2 or higher. TLS 1.0 and 1.1 are deprecated and shall not be used.

4.2 ePHI AT REST: All ePHI stored on servers, databases, workstations, and portable media shall be encrypted using AES-256 (Advanced Encryption Standard, 256-bit key). Unencrypted ePHI shall not be stored on any portable device (laptop, USB drive, tablet) unless the device implements full-disk encryption meeting AES-256 standard.

4.3 EMAIL: No ePHI shall be transmitted via standard unencrypted email. All email communication containing ePHI must use an approved secure messaging platform or encrypted email gateway. Staff shall not forward ePHI to personal email accounts under any circumstances.

4.4 REMOTE ACCESS: All remote access connections to ePHI systems shall use a VPN with AES-256 encryption and MFA. Direct RDP or SSH connections to ePHI servers from external networks are prohibited without VPN.

4.5 KEY MANAGEMENT: Encryption keys shall be managed by the IT Department. Key access shall be restricted to IT administrators only. Key rotation shall occur annually or immediately following a suspected key compromise. All key management activities shall be logged.

4.6 ENCRYPTION VERIFICATION: The IT Department shall verify encryption is active and correctly configured on all ePHI systems on a quarterly basis. Any system found to be storing or transmitting unencrypted ePHI shall be immediately isolated pending remediation.

## 5.0 POLICY COMPLIANCE

Transmission or storage of unencrypted ePHI constitutes a potential HIPAA breach and a violation of this policy. Violations may result in disciplinary action, mandatory HHS breach notification, and civil penalties. The HITECH Breach Notification Safe Harbour (45 CFR §164.402) may be claimed only where encryption meets the standards defined in this policy.

## 6.0 RELATED DOCUMENTS

SEC-POL-001 (PHI Access Control Policy) | HIPAA 45 CFR §164.312(e)(2)(ii) | HITECH Act 45 CFR §164.402 | NIST SP 800-111 (Storage Encryption) | ISO 27001:2022 A.8.24

| Policy 3 | Authentication & Password Policy | SEC-POL-003 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# AUTHENTICATION & PASSWORD POLICY

SEC-POL-003 | Version 1.0 | INTERNAL

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / IT Manager | [Insert Effective Date] | A.5.17 \| A.8.5 | ISO 27001 + SANS Password Protection Policy |

**Analyst Note:** *The SANS Password Protection Policy template was the primary language source here, it has the clearest password requirement clauses I found. I extended it significantly with the MFA mandate for all EHR access (which SANS does not include by default) and referenced ISO 27001 A.8.5 (Secure Authentication) as the control requirement. HIPAA does not prescribe specific password length or complexity but requires 'procedures for creating, changing, and safeguarding passwords', so I aligned to the NIST SP 800-63B digital identity guidelines for the specific technical requirements.*

## 1.0 OVERVIEW

Compromised credentials are the leading cause of healthcare data breaches globally. Single-factor password authentication for systems containing PHI or ePHI represents an unacceptable risk when credential theft through phishing, brute-force, or password reuse is common. This policy establishes mandatory multi-factor authentication for all PHI system access and minimum password standards aligned to NIST SP 800-63B guidance.

## 2.0 PURPOSE

The purpose of this policy is to establish minimum authentication requirements for all accounts accessing PHI or ePHI systems, mandate multi-factor authentication (MFA) for all EHR and clinical system access, and define password creation, management, and protection standards that satisfy HIPAA Administrative Safeguard requirements (45 CFR §164.308(a)(5)) and ISO 27001 Annex A.8.5.

## 4.0 POLICY, AUTHENTICATION REQUIREMENTS

4.1 MULTI-FACTOR AUTHENTICATION (MFA): MFA is mandatory for all access to systems containing PHI or ePHI. This includes: Electronic Health Record (EHR) systems, all servers on VLAN 10 and VLAN 20, all remote access connections via VPN, and the Splunk SIEM platform. MFA shall use at least two of: something you know (password), something you have (authenticator app, hardware token), something you are (biometric). SMS-based OTP is permitted as a temporary measure only pending migration to authenticator app or hardware token.

4.2 PASSWORD LENGTH: All passwords for accounts with PHI access must be a minimum of 14 characters. System administrator and privileged accounts must use a minimum of 16 characters.

4.3 PASSWORD COMPLEXITY: Passwords shall contain at least one uppercase letter, one lowercase letter, one number, and one special character (!@#$%^&*). Common words, names, dictionary terms, and patterns (e.g. Password1!, Healthcare1!) are prohibited.

4.4 PASSWORD ROTATION: Passwords shall be changed every 90 days for standard user accounts and every 60 days for privileged accounts. Passwords shall not be reused within the previous 12 changes.

4.5 PASSWORD STORAGE & SHARING: Passwords shall never be shared between users. Passwords shall not be written on physical media or stored in plain text files. All staff are encouraged to use an organisation-approved password manager. Sharing of any account credentials is a disciplinary offence.

4.6 ACCOUNT LOCKOUT: Accounts shall be locked after 5 consecutive failed login attempts. Locked accounts shall require manual reset by the IT Department after verification of the user's identity. This threshold applies to all PHI-bearing systems.

4.7 DEFAULT CREDENTIALS: All default manufacturer credentials on any device or system shall be changed before the device or system is connected to the network. Default credentials on network devices, servers, or applications are a critical security failure.

## 5.0 POLICY COMPLIANCE

Failure to comply with MFA requirements is a Critical policy violation and shall result in immediate account suspension pending investigation. Sharing of credentials is grounds for immediate disciplinary action including termination. Violations that result in PHI exposure shall be treated as potential HIPAA breaches.

| Policy 4 | Audit Logging & Monitoring Policy | SEC-POL-004 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# AUDIT LOGGING & MONITORING POLICY

SEC-POL-004 | Version 1.0 | INTERNAL, RESTRICTED

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / IT Manager | [Insert Effective Date] | A.8.15 \| A.8.16 | ISO 27001 + SANS Audit Policy Template |

**Analyst Note:** *ISO 27001 A.8.15 (Logging) and A.8.16 (Monitoring Activities) provided the control framework. The SANS Audit Policy template gave me the clause structure. The key customisation was adding the HIPAA audit control requirement (45 CFR §164.312(b)), which mandates hardware, software, and procedural mechanisms to record and examine activity in systems containing ePHI. I also added the Splunk SIEM integration as the specific monitoring tool and set a 90-day minimum log retention period aligned to common HIPAA guidance.*

## 1.0 OVERVIEW

Without comprehensive audit logging of PHI access events, the organisation cannot detect insider threats, investigate potential breaches, or produce evidence for HIPAA investigations. HIPAA requires covered entities to implement hardware, software, and procedural mechanisms that record and examine activity in systems containing ePHI (45 CFR §164.312(b)). This policy establishes mandatory logging of all PHI access events and defines the monitoring, review, and retention requirements.

## 4.0 POLICY, LOGGING & MONITORING REQUIREMENTS

4.1 MANDATORY LOGGING: The following events shall be logged for all systems containing PHI or ePHI: user login and logout events; PHI record access events (view, create, modify, delete); failed login attempts; privilege escalation events; administrative configuration changes; system startup and shutdown; remote access connections.

4.2 LOG INTEGRITY: All audit logs shall be stored in a tamper-evident format. Logs shall be written to a centralised logging system (SIEM, Splunk Enterprise) that is isolated from the systems generating the logs. Staff shall not have the ability to modify or delete audit logs from systems they operate.

4.3 LOG RETENTION: Audit logs covering PHI access events shall be retained for a minimum of 90 days in an immediately searchable format on the SIEM platform. Archived logs shall be retained for a minimum of 6 years in compliance with HIPAA's documentation retention requirement (45 CFR §164.316(b)(2)).

4.4 MONITORING: The Information Security team shall review PHI access audit logs on a monthly basis. The SIEM platform (Splunk) shall be configured with automated alerts for: more than 5 failed login attempts against a PHI system (potential brute force); access to PHI records

outside normal business hours (08:00–18:00) by a standard user; bulk access to PHI records (more than 50 records in a single session); access from an unrecognised device or IP address.

4.5 RESPONSE: Any anomalous PHI access event identified through log review or SIEM alert shall be investigated within 24 hours of detection. Investigations shall be documented. If investigation confirms an unauthorised PHI access, the Breach Notification Policy (SEC-POL-005) shall be activated.

4.6 SIEM PLATFORM: Splunk Enterprise is the designated SIEM platform. All PHI-bearing systems on VLAN 10 and VLAN 20 shall be configured to forward Windows Security Event logs (minimum EventCode 4624, 4625, 4634, 4648, 4740) to the Splunk indexer via the Splunk Universal Forwarder.

| Policy 5 | Breach Notification Policy | SEC-POL-005 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# BREACH NOTIFICATION POLICY

SEC-POL-005 | Version 1.0 | INTERNAL, CRITICAL

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / CISO / Legal | [Insert Effective Date] | A.5.24 \| A.5.26 | ISO 27001 + SANS Security Response Plan Policy |

📋 **Analyst Note:** *This was the most legally sensitive policy to draft. ISO 27001 A.5.24 (Information Security Incident Management Planning and Preparation) provided the incident management framework. SANS Security Response Plan gave me the response structure. The critical HIPAA-specific content, the 60-day notification window, HHS reporting requirement, the 500-individual media threshold, and the HITECH safe harbour, had to be added entirely from the regulatory text. These elements do not exist in either template and are the most important parts of this policy for the organisation.*

## 1.0 OVERVIEW

A PHI or ePHI breach is not only a security incident, it is a regulatory event that triggers mandatory legal obligations under HIPAA and HITECH. Failure to notify affected individuals, HHS, or the media within the required timeframes may itself constitute a HIPAA violation, compounding the original breach penalty. This policy defines what constitutes a HIPAA breach, who must be notified, within what timeframe, and what records must be maintained.

## 4.0 POLICY, BREACH NOTIFICATION REQUIREMENTS

4.1 BREACH DEFINITION: A breach is defined as any acquisition, access, use, or disclosure of PHI or ePHI in a manner not permitted by the HIPAA Privacy Rule that compromises the security or privacy of the PHI. A breach is presumed to have occurred unless the covered entity demonstrates a low probability that the PHI has been compromised based on a four-factor risk assessment.

4.2 BREACH ASSESSMENT (FOUR-FACTOR TEST): Upon discovery of a potential breach, the Information Security Officer shall conduct an immediate risk assessment covering: (1) the nature and extent of the PHI involved; (2) the identity of the unauthorised person who accessed the PHI; (3) whether the PHI was actually acquired or viewed; (4) the extent to which the risk to the PHI has been mitigated. Assessment must be documented and completed within 24 hours.

4.3 INDIVIDUAL NOTIFICATION: Affected individuals shall be notified without unreasonable delay and in all cases no later than 60 days after discovery of the breach. Notification shall be by first-class mail (or email if the individual has agreed to electronic notice). The notification shall include: description of what occurred; PHI involved; steps individuals can take to protect themselves; steps the organisation is taking; contact details for questions.

4.4 HHS NOTIFICATION: The organisation shall notify the Department of Health and Human Services (HHS) of all breaches. For breaches affecting fewer than 500 individuals: submit to HHS

annually (within 60 days of end of calendar year). For breaches affecting 500 or more individuals: notify HHS simultaneously with individual notification (within 60 days of discovery).

4.5 MEDIA NOTIFICATION: For breaches affecting 500 or more individuals in a state or jurisdiction, the organisation shall notify prominent media outlets serving that state or jurisdiction without unreasonable delay and within 60 days of discovery.

4.6 ENCRYPTION SAFE HARBOUR: A breach involving ePHI that was encrypted to the standard defined in SEC-POL-002 (ePHI Encryption Policy) at the time of the breach may qualify for the HITECH Breach Notification Safe Harbour and may not require notification. This determination shall be made by the CISO with legal counsel.

4.7 BREACH LOG: All breaches, confirmed and suspected, shall be documented in the organisation's Breach Log and retained for a minimum of 6 years from the date of creation.

## 5.0 POLICY COMPLIANCE

Failure to report a confirmed breach within the required HIPAA notification timeframes constitutes a separate HIPAA violation and may be treated as wilful neglect (Tier C/D penalties: $10,000–$50,000 per violation, up to $1.5 million annual cap). All staff who discover a potential breach must report it to the Information Security Officer immediately, delayed reporting by staff is a disciplinary offence.

| Policy 6 | Acceptable Use Policy | SEC-POL-006 |
|---|---|---|

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

# ACCEPTABLE USE POLICY

SEC-POL-006 | Version 1.0 | INTERNAL, ALL STAFF

| Policy Owner | Effective Date | ISO 27001 Controls | Template Source |
|---|---|---|---|
| Cybersecurity Analyst / HR Manager | [Insert Effective Date] | A.6.3 \| A.5.1 | ISO 27001 + SANS Acceptable Use Policy Template |

📋 **Analyst Note:** *The SANS Acceptable Use Policy template was the primary source here, it is one of the most comprehensive and widely used AUP templates available. I retained most of the SANS structure but added healthcare-specific sections: the clinical workstation requirements (auto-lock, no personal use in clinical areas), the PHI device handling rules, and the VLAN-specific visitor/guest network restrictions. ISO 27001 A.6.3 (Awareness, Education and Training) is satisfied by requiring staff to read and acknowledge this policy annually.*

## 1.0 OVERVIEW

The Healthcare Clinical & Administrative Centre's information systems and network resources exist to support the delivery of healthcare services and administrative operations. All staff have a responsibility to use these resources appropriately, to protect patient data, and to avoid actions that could expose PHI, compromise system security, or violate HIPAA regulations. This policy defines the acceptable and unacceptable uses of the organisation's systems, networks, and data.

## 4.0 POLICY, ACCEPTABLE USE REQUIREMENTS

4.1 AUTHORISED USE: Organisation systems, networks, and devices shall be used primarily for business purposes. Limited, incidental personal use is permitted provided it does not interfere with work duties, consume significant network bandwidth, or involve access to material that is illegal, offensive, or contrary to organisational values.

4.2 PROHIBITED USES: The following are strictly prohibited on all organisation systems and networks: accessing, downloading, or distributing PHI without authorisation; installing unauthorised software or applications; connecting personal devices to PHI-bearing VLANs (VLAN 10–40) without IT approval and MDM enrolment; accessing the Dark Web, peer-to-peer file sharing networks, or gambling sites; sharing login credentials with any other person; attempting to access systems or data not within one's authorised role.

4.3 CLINICAL WORKSTATION REQUIREMENTS: Workstations in clinical areas (VLANs 10 and 20) shall auto-lock after 5 minutes of inactivity (enforced by Group Policy). Clinical workstations shall not be used for personal internet browsing or entertainment. PHI displayed on-screen shall not be visible to visitors or unauthorised persons. The clean desk policy requires all PHI (physical and on-screen) to be secured before a workstation is left unattended.

4.4 PHI DEVICE HANDLING: PHI shall not be printed unless operationally necessary. All PHI printouts shall be collected immediately from printers and either filed securely or shredded. PHI

shall not be photographed or copied to personal devices. Transfer of PHI to portable media (USB drives, external disks) is prohibited unless the media is encrypted and IT-approved.

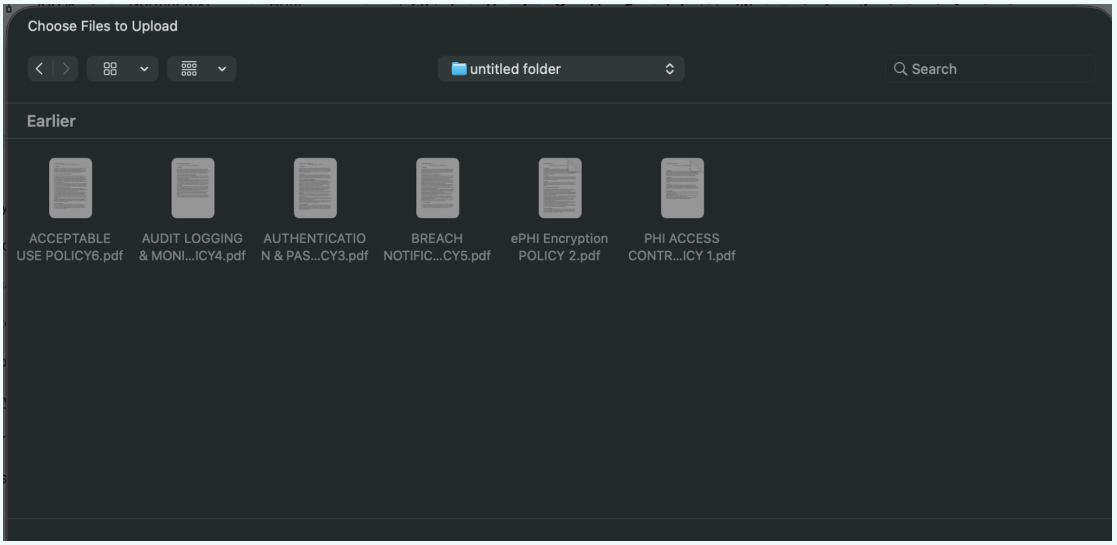
4.5 GUEST AND VISITOR NETWORK: Visitors and guests shall use the Guest VLAN (VLAN 50) exclusively. Guest VLAN devices have no access to PHI systems (enforced by firewall ACL). Staff shall not provide visitor devices with credentials to connect to any VLAN other than VLAN 50.

4.6 REMOTE WORKING: Staff working remotely must connect to PHI systems exclusively via the organisation-approved VPN with MFA. PHI shall not be stored on personal devices. Screen-sharing PHI during video calls requires that all non-authorised participants have left the meeting before PHI is displayed.

4.7 POLICY ACKNOWLEDGEMENT: All staff with access to PHI systems shall read, understand, and digitally acknowledge this policy annually. New staff shall acknowledge the policy before being granted access to any PHI system. Policy acknowledgement records shall be maintained by HR and reviewed by the Information Security team.

## 5.0 POLICY COMPLIANCE

Violations of this policy will be assessed individually and may result in verbal warning, written warning, suspension, or immediate termination depending on severity. Any violation that results in PHI exposure shall be treated as a potential HIPAA breach and escalated to the Breach Notification process (SEC-POL-005). The organisation reserves the right to monitor all activity on its systems and networks for compliance with this policy.



# 13. ISO 27001 Annex A Control Mapping, All 6 Policies

The table below provides the complete ISO 27001 Annex A compliance evidence for the full policy suite, showing exactly which Annex A controls each policy satisfies. This table is the primary deliverable for an ISO 27001 auditor reviewing the organisation's policy documentation against the Annex A requirements.

| Annex A Control | Control Name | Requirement | Policy Satisfying It |
|---|---|---|---|
| A.5.1 | Information Security Policies | Policies shall be defined and reviewed at planned intervals | All 6 policies, SEC-POL-001 to 006 |
| A.5.15 | Access Control | Rules for access control shall be established based on business and security requirements | SEC-POL-001 (PHI Access Control) |
| A.5.16 | Identity Management | Lifecycle of identities shall be managed | SEC-POL-001 (JML process) |
| A.5.17 | Authentication Information | Allocation and management of authentication information shall be controlled | SEC-POL-003 (Authentication & Password) |
| A.5.24 | Information Security Incident Management | Information security incident management responsibilities shall be planned | SEC-POL-005 (Breach Notification) |
| A.6.3 | Awareness, Education and Training | Personnel shall receive awareness and training | SEC-POL-006 (AUP acknowledgement) |
| A.8.2 | Privileged Access Rights | Allocation and use of privileged access rights shall be restricted | SEC-POL-001 (RBAC & least privilege) |
| A.8.5 | Secure Authentication | Secure authentication technologies and procedures shall be implemented | SEC-POL-003 (MFA mandate) |
| A.8.11 | Data Masking | Data masking shall be used in accordance with risk and policies | SEC-POL-002 (ePHI protection) |
| A.8.15 | Logging | Event logs recording user activities shall be produced, stored, protected and analysed | SEC-POL-004 (Audit Logging) |
| A.8.16 | Monitoring Activities | Networks, systems and applications shall be monitored | SEC-POL-004 (SIEM monitoring) |
| A.8.24 | Use of Cryptography | Rules for the use of cryptography shall be defined and implemented | SEC-POL-002 (ePHI Encryption) |

# 14. Policy Suite Implementation Plan

Producing the policy documents is only the first step. The following implementation plan defines how each policy is operationalised, moving from a document on the intranet to a live, enforced control.

| Policy | Key Implementation Action | Technical Control Required | Owner | Timeline |
|---|---|---|---|---|
| SEC-POL-001Access Control | Conduct RBAC role definition per VLAN; remove excess access | Active Directory RBAC groups; quarterly access review process | IT Manager | 30 days |
| SEC-POL-002Encryption | Audit all ePHI systems for encryption compliance; deploy TLS 1.2+ | TLS configuration on servers; BitLocker/AES-256 on workstations; VPN | IT Manager | 30 days |
| SEC-POL-003Authentication | Enforce MFA across all EHR and PHI systems; update password GPO | Azure AD / AD MFA; GPO password policy (14 char min, 90-day rotation) | IT Manager | 14 days |
| SEC-POL-004Audit Logging | Configure Splunk UF on all PHI-bearing systems; set SIEM alerts | Splunk Enterprise SIEM; UF on VLAN 10/20 servers; alert thresholds | Cyber Analyst | 21 days |
| SEC-POL-005Breach Notification | Brief incident response team; create breach log template; test procedure | Breach log spreadsheet; HHS reporting account; notification templates | CISO / Legal | 7 days |
| SEC-POL-006Acceptable Use | Distribute to all staff; collect signed acknowledgements; deliver training | Digital acknowledgement system; HR records; annual training schedule | HR + Cyber Analyst | 21 days |

# 15. Key Lessons, What the Analyst Learned

| # | Lesson | Detail |
|---|---|---|
| L-1 | **Templates accelerate quality, but customisation is where the real work is** | The ISO 27001 and SANS templates gave me structure, vocabulary, and completeness assurance. But every policy's value came from the customisation: adding the HIPAA regulatory citations, the VLAN-specific controls, and the healthcare-specific risks. A template without customisation is a liability, it implies controls that may not match the organisation's actual environment. |
| L-2 | **ISO 27001 and SANS templates are complementary, not competing** | ISO 27001 Annex A tells you WHAT controls are required. SANS templates show you HOW to write those controls in language staff can understand and auditors can verify. Using both together produces policies that are simultaneously technically rigorous and operationally readable, a combination neither template achieves alone. |
| L-3 | **The risk register is the policy architecture document** | Every policy in this suite exists because a specific row in the risk register had no adequate control. Building the policy suite from the risk register means there are no orphan policies (policies that don't address a known risk) and no unaddressed risks (risks without a policy control). This traceability is exactly what an ISO 27001 or HIPAA auditor will look for. |
| L-4 | **HITECH's Encryption Safe Harbour is the most important addition to any HIPAA encryption policy** | The SANS Data Classification template and ISO 27001 A.8.24 both mention encryption but neither mentions the HITECH Breach Notification Safe Harbour. This legal carve-out, that properly encrypted ePHI may not require breach notification even if breached, is arguably the highest-ROI clause in the entire policy suite. Adding it to SEC-POL-002 transforms encryption from a compliance cost into a breach liability management strategy. |
| L-5 | **Policies are living documents, the review cycle is as important as the initial draft** | A policy that is written once and filed is not a security control, it is a document. The annual review requirement, triggered-review conditions (HIPAA update, new VLAN, EHR change, breach), and version control built into every policy ensure that the suite evolves with the organisation's risk landscape rather than becoming stale and irrelevant within 12 months. |

# 16. Screenshot Evidence Index

| # | Screenshot Caption | Section | Source |
|---|---|---|---|
| 1 | ISO 27001:2022 Annex A Controls List (Source Document) | 2, Template Selection | ISO 27001 Standard / Reference Site |
| 2 | SANS Institute, Policy Template Library (sans.org) | 2, Template Selection | sans.org/information-security-policy |
| 3 | Risk Register, All 6 Risks Mapped to Policies | 6, Risk Register | Risk Register Spreadsheet |
| 4 | SEC-POL-001, Signed PHI Access Control Policy (Final) | 7, Policy 1 | Policy Document |
| 5 | Active Directory, RBAC Role Groups per VLAN (Implementation) | 14, Implementation Plan | Active Directory Users & Computers |
| 6 | SEC-POL-002, ePHI Encryption Policy (Final) | 8, Policy 2 | Policy Document |
| 7 | TLS/Encryption Verification, Server Certificates Active | 14, Implementation Plan | IIS Manager / SSL Tool |
| 8 | SEC-POL-003, Authentication & Password Policy (Final) | 9, Policy 3 | Policy Document |
| 9 | Azure AD / Active Directory, MFA Enforced on PHI Accounts | 14, Implementation Plan | Azure AD / AD MFA Console |
| 10 | SEC-POL-004, Audit Logging & Monitoring Policy (Final) | 10, Policy 4 | Policy Document |
| 11 | Splunk, SIEM Dashboard with PHI Access Alerts Active | 14, Implementation Plan | Splunk Enterprise SIEM |
| 12 | SEC-POL-005, Breach Notification Policy (Final) | 11, Policy 5 | Policy Document |
| 13 | SEC-POL-006, Acceptable Use Policy (Final with Staff Signatures) | 12, Policy 6 | Policy Document + HR Records |
| 14 | All 6 Policies, Complete Policy Suite Overview | 12, Policy Suite Complete | Policy Documents Folder |
| 15 | ISO 27001 Annex A Compliance Evidence, All 6 Policies Mapped | 13, ISO Mapping Table | Compliance Evidence Document |

**End of Security Policy Development Documentation**

Healthcare Clinical & Administrative Centre | ISO 27001 & SANS Templates | 6 Policies | HIPAA | HITECH